Role & Permission Matrix

> Derived from `apps/api/src/shared/roles.ts`, every `@Roles(...)` / `@Public()` decorator in `apps/api/src/modules/**`, the web route guards in `apps/web/src/routes/router.tsx` and `apps/web/src/employer/routes/`, and `ROLE_HOME` in `apps/web/src/types/roles.ts`. Commit `8de48cf`.

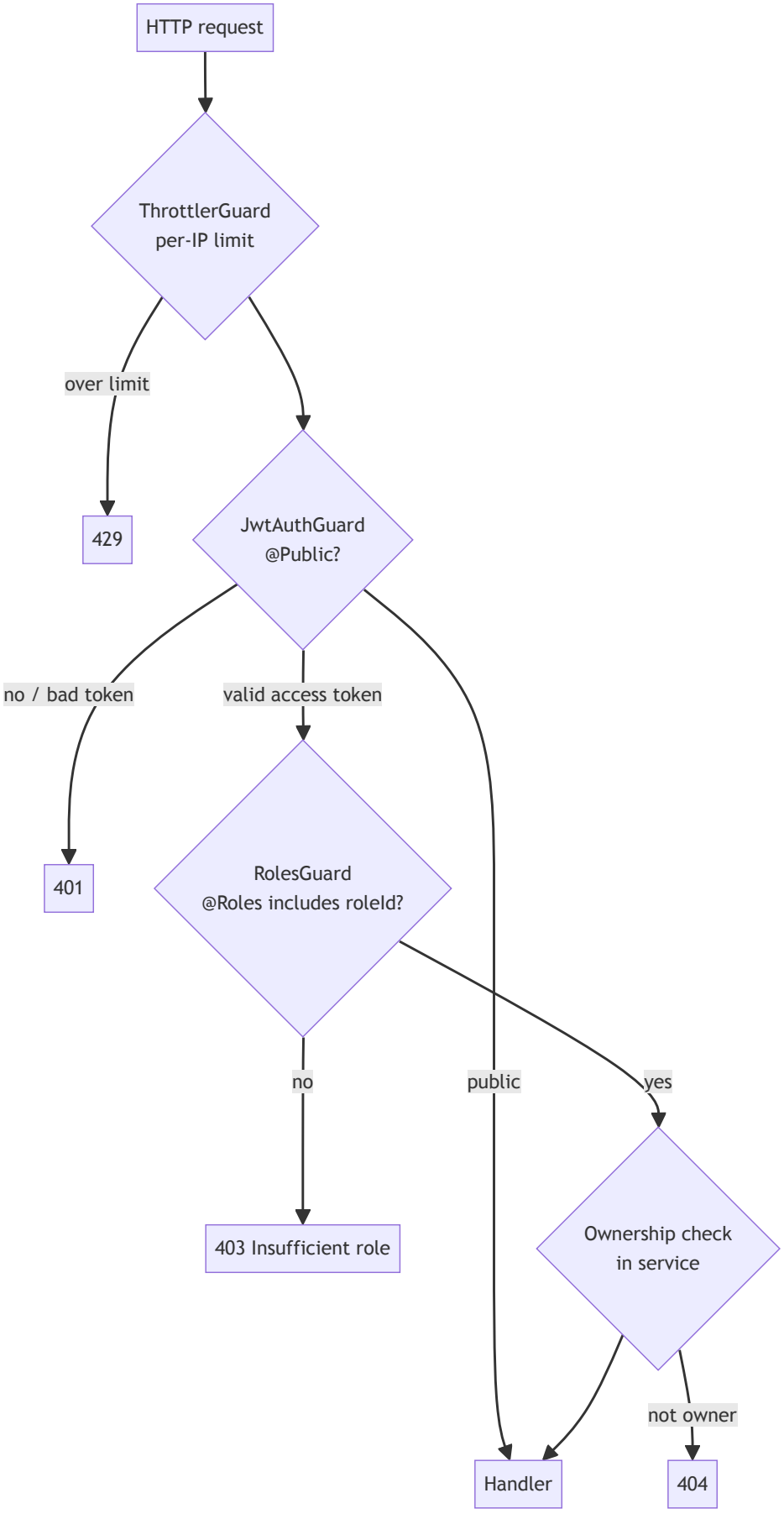
1. Roles that exist in code

Id	Code name	UI label	Implemented?	Home route after login	How the account is created
1	`Subscriber`	Candidate	**Yes**	`/candidate/profile` (→ `/candidate/onboarding` until onboarded)	Self-registration with email OTP (`POST /api/auth/register` → `/verify-otp`)
2	`QC1`	QC1 (Q1 screening)	**Yes**	`/q1/dashboard`	Admin creates staff login (`POST /api/admin/users`) or seed
3	`QC2`	QC2 (Q2 matching)	**Yes**	`/q2/dashboard`	Admin / seed
4	`Client`	Employer	**Yes**	`/company` (employer portal)	Public employer registration → **Admin approval** creates the login and emails a temporary password
5	`Admin`	Admin	**Yes**	`/admin`	Admin, seed, or CLI `apps/api/scripts/create-admin.ts`
6	`Subscription`	Subscription	**Not implemented** — the id exists, `ROLE_HOME` points to `/pricing`, but no API route references it and payment never assigns it	`/pricing`	Never assigned
7	`Q3`	Q3 (interview coordination / hiring ops)	**Yes**	`/q3/dashboard`	Admin / seed

Demo accounts (dev/CI only, created by `apps/api/prisma/seed.ts` with `SEED_DEMO_USERS=1`): `anuj` (candidate), `qc1`, `qc2`, `anuj@aajiveka.com` (employer), `admin`, `q3` (`seed.ts:190-197`). Passwords are not reproduced here. Staff/admin logins are created with `NodeType 100`, which the email-login path excludes (`auth.service.ts:197`), so **staff can log in by username but not by email** (employers use NodeType 200 and are unaffected).

Proposed / implied but not implemented: company sub-users or team members (one login per company only); a "Subscription" membership role; candidate-facing "Recruiter" messaging (privacy flag `allowRecruiterMessages` exists, no messaging module is routed).

2. How access is enforced



- **Server**: global guards (`apps/api/src/app.module.ts`). Ownership is checked inside services: candidates by `tblSecUser.SubscriberID` ; employers by `tblSecUser.NodeID → tblMstrPerson.ClientID` (`clientIdFor`); shared hiring routes

by `MappingAccessService` (checks Candidate and Client only — staff roles pass through).

- **Client**: `ProtectedRoute` (`apps/web/src/routes/ProtectedRoute.tsx`) redirects anonymous users to `/login`, wrong roles to their `ROLE_HOME`, and non-onboarded candidates to `/candidate/onboarding`. Client guards were deliberately aligned to the server's `@Roles` lists (commit `2eb4db7` referenced in router comments).
- **Token lifetime caveat**: the access token's `roleId` is trusted for its full TTL (default 15 min). Deactivation or a role change takes effect for API calls only after the access token expires.

3. Responsibility matrix (who does what)

Legend: **C** create · **R** read · **U** update · **D** delete · **A** approve/decide · — no access. "own" = restricted to the user's own records.

Capability	Candidate (1)	QC1 (2)	QC2 (3)	Employer (4)	Q3 (7)	Admin (5)	Public
Register / log in	C (self)	login	login	C registration (pending) → login after approval	login	login	browse
Own profile & CV	CRUD own	R all candidates	R all	R applicants of own jobs	R referred	R all	—
Upload resume / photo / requested docs	C own	—	—	logo only	—	—	—
Browse / search jobs	R	—	R active jobs	R own jobs	—	R all	R active (and any job by id)
Apply to job	C (needs active subscription)	C on behalf (assign-job)	C on behalf	—	—	C on behalf	—
Post / edit / close / archive / delete jobs	—	—	—	CRUD own	—	Close / Reopen only	—
Q1 screening (verify, follow-up, no-response, not-interested, checklist, contact log)	—	**A**	—	—	—	A	—
Registration decision (Approved/Rejected/OnHold/…)	—	**A**	—	—	—	A	—
Match scoring & Q2 decisions (forward to Q3, send back to Q1, reject)	—	score only	**A**	—	—	A	—
Refer CVs to Q3	—	—	C	—	—	C	—
Forward CVs to company / return to Q2	—	—	—	—	**A**	A	—
Company review of forwarded CV (shortlist / reject)	—	—	—	**A** own	capture on company's behalf (round-setup)	A (only if linked to a company — effectively 404)	—
Employer decision on any own applicant (Shortlisted / Hired / Rejected / undo)	—	—	—	**A** own	—	404 (no company)	—
Create interview rounds, slots	—	—	—	C own	C (any mapping via /recruitment)	C	—
Confirm slot / send invites	pick own slot	—	—	—	**A**	A	—
Record round result / decision	—	—	—	**A** own (submitResult)	**A** (Q3 decide)	A	—
Request / verify / send back documents	upload own	verify/reject any (legacy)	assign doc types; verify (legacy)	request & review own applicants	**A** request, verify, forward, approve	A	—
Create / send offer	—	—	—	C own	**A**	A	—
Accept / reject offer	**A** own	—	—	—	—	A (on behalf)	—
Mark joined	—	—	—	U own	**A**	A	—
Legacy interviews (tblJobInterviewStatus)	—	C/U	C/U	—	—	C/U	—
Employer registration approval	—	—	—	—	—	**A**	—

Capability	Candidate (1)	QC1 (2)	QC2 (3)	Employer (4)	Q3 (7)	Admin (5)	Public
User management (create staff, active flag, role, reset link)	—	—	—	—	—	**CRUD**	—
Platform settings	—	—	—	—	—	R/U (not enforced anywhere)	—
Blog CMS	—	—	—	—	—	CRUD	R (public pages)
Audit log	—	—	—	—	—	R	—
Exports	—	candidates	candidates	applicants (10-row bug)	—	users, jobs, applications, payments, candidates	—
Analytics	own dashboard	Q1 analytics	Q2 analytics	own company analytics	Q3 dashboard & quarterly report	platform stats	—
Payments / subscription	C/R own	—	—	R own invoices (no online payment)	—	export	R plans
Notifications (SSE / in-app)	R (always empty)	R	R	R	R	R	—

4. Per-role detail

4.1 Candidate (Subscriber, 1)

- **Pages**: public site, `/jobs`, `/jobs/:id`, `/jobs/:id/apply`, `/candidate/applications`, `/candidate/saved-jobs`, portal (`/candidate/profile`, `/onboarding`, `/tracker`, `/interviews`, `/documents`, `/referrals`, `/account`, `/notifications`, `/all-notifications`, `/resume-builder`), `/candidate/subscription`.
- **Can**: build profile (personal, professional, education, employment, certificates, skills, projects, languages, etc.), upload resume/photo, save jobs, set alerts and saved searches (stored only), pay for a subscription (Razorpay), apply, pick an interview slot (shared `/recruitment/interview-rounds/:roundId/select-slot`), upload requested documents, accept/reject an offer, refer friends (stored only), change password, request data export / account deletion (recorded only).
- **Cannot**: see other candidates; change application status (except offer response); withdraw an application (no endpoint).
- **Depends on**: QC1/QC2/Q3/Employer to move applications; Admin for nothing directly.
- **Restrictions**: must complete onboarding before any other candidate route; apply needs an active subscription; legacy (migrated) candidates are not linked to a profile and get 404 on all `/candidates/me*` routes.

4.2 QC1 (2) — Q1 screening

- **Pages**: `/q1/*` (dashboard, candidates, candidate profile, follow-ups, no-response, verified, not-interested, analytics). Also legacy `/recruitment/candidates`, `/recruitment/candidates/:id`, `/recruitment/documents`, `/recruitment/interviews`, `/recruitment/qc1`.
- **Can**: work the screening queue, open a profile (New → Screening), tick the 7-item checklist, log contacts (no message is actually sent), set FollowUp/NoResponse/NotInterested, mark Verified, make registration decisions, compute match scores, assign a candidate to a job, schedule/close legacy interviews, list/download/verify any candidate document, export candidates.
- **Status changes**: screening status (string state); registration `flgstatus`; legacy interview statuses 3/6/9; any status via the unused `PATCH /recruitment/pipeline/:id`.
- **Hand-off**: Q1 "Verified" is **not enforced** as a gate — Q2 sees all applications on active jobs regardless.

4.3 QC2 (3) — Q2 matching

- **Pages**: `/q2/*` (dashboard, employer jobs, job applicants, all applicants, applicant detail, forwarded, sent-back, analytics); legacy `/recruitment/*` incl. `/recruitment/referrals`.
- **Can**: view ranked applicants per job (scores are computed lazily), toggle score criteria, **forward to Q3** (→ 14 REFERRED_TO_Q3), **send back to Q1** (→ 11 NEED_MORE_INFO, screening → Incomplete), **reject** (→ 5), assign document types, legacy interview and document actions.
- **Depends on**: Q1 (advisory), Q3 (returns CVs with a reason; auto-expiry returns them after 14 days).

4.4 Employer (Client, 4)

- **Pages**: employer portal under `/company/*` (see FRONTEND_BACKEND_MAPPING). Public: `/register/employer`.

- **Can**: manage company profile/logo, post/edit/close/archive/reactivate/duplicate/delete own jobs (delete only without applications), CSV bulk-upload jobs, view **all** applicants on own jobs with contact details, shortlist/hire/reject (and undo), request first interview round with 3 slots, record round results (Select → next round / Hire, Reject, Hold), request and review documents for selected candidates, create/send offers and mark joined via shared routes, add private notes, view analytics and invoices, export CSVs.
- **Cannot**: add team members, pay invoices online, see other companies' jobs.
- **Restrictions / gaps**: can act on applicants not yet released by QC1→QC2→Q3 (product decision needed); document list/review is scoped to the candidate rather than the application.

4.5 Q3 (7) — interview coordination & hiring ops

- **Pages**: `/q3/*` (dashboard, referred, company-review, scheduling, interviews, decisions, documents, offers, returned). Sidebar also links legacy `/recruitment/q3/*` — the candidate list and interviews screens there call `/recruitment/*` endpoints that **exclude Q3** (403).
- **Can**: forward referred CVs to the company (14-day window starts) or return them to Q2; capture company shortlist & panel; request slots from HR; confirm a slot and send invites (Jitsi link optional); remind, reschedule, mark conducted; chase companies for results; record round decisions (NextRound / FinalRound / Hold / Rejected / Selected); request, verify, send back, forward and approve documents; generate & send the offer; mark joined; quarterly report.
- **Scope gap**: through `/recruitment/*` routes Q3 can act on applications never referred to Q3.

4.6 Admin (5)

- **Pages**: `/admin/*` (dashboard, users, user detail, employer approvals, companies, jobs, job detail, applications, application detail, blog, settings, reports, audit). Also admitted to every Q1/Q2/Q3/recruitment/employer route.
- **Owns**: employer registration approval/rejection; job Active ↔ Closed; user active flag and staff role (never self, never across candidate/employer/staff lines); staff account creation; password-reset links; platform settings (stored, not enforced); blog posts; exports; audit log.
- **By design read-only over the hiring pipeline**: `/admin/applications/:mapId` shows a "next step" link to the owning workspace instead of duplicating transitions.
- **Effectively blocked**: employer `me/*` routes and the company-review route return 404 for Admin (no linked company).

5. Client-route ↔ server-role alignment

Web route group	Client guard (`allow`)	Server roles of the APIs it calls	Aligned?
`/candidate/*` , `/jobs/:id/apply`	Subscriber	Subscriber	Yes
`/q1/*`	QC1, Admin	`/q1/*` QC1, Admin	Yes
`/q2/*`	QC2, Admin	`/q2/*` QC2, Admin	Yes
`/q3/*`	Q3, Admin	`/q3/*` Q3, Admin	Yes
`/admin/*`	Admin	`/admin/*` Admin	Yes
`/recruitment/candidates` , `/documents` , `/interviews`	QC1, QC2, Admin	QC1, QC2, Admin	Yes
`/recruitment/qc1`	QC1, Admin	QC1, Admin	Yes
`/recruitment/referrals`	QC2, Admin	list QC2/Q3/Admin, create QC2/Admin	Yes
`/recruitment/q3/candidates` , `/q3/interviews` , `/q3/documents`	Q3, Admin	`/recruitment/candidates` , `/interviews` , `/documents` = QC1, QC2, Admin	**No — Q3 gets 403**
Employer portal	Client, Admin	`/clients/*` Client, Admin (Admin → 404 no company)	Partially (Admin unusable)